INFORME FINAL · PRÁCTICAS PROFESIONALES

Programa de Attack Surface Management (ASM)

5 vectores auditados, vulnerabilidades remediadas y evidencia documentada — AICO

AUTOR

Jesús Alejandro Rodríguez Medina

FORMACIÓN

TSU en Seguridad Informática — Universidad ONMEX (RVOE 2894)

PERFIL OBJETIVO

Consultor Jr. Ciberseguridad · Analista DevSecOps · SOC N1

ORGANIZACIÓN / PROYECTO

AICO — Attack Surface Management (ASM)

Red Team → Blue Team | ISO/IEC 27001 | CIS Benchmarks | OWASP WSTG · MASVS | NIST SP 800-115

Código: REP-ASM-2026-FIN01

✓ 5 / 5 MAPEOS COMPLETADOS

1. Resumen del Proyecto y Valor para las Empresas

> La ciberseguridad no es una lista de vulnerabilidades: es un **habilitador del negocio**. Este programa demuestra un enfoque que va más allá de encontrar fallas: se **identifica** la superficie de ataque con técnicas pasivas y no destructivas, se **valida el riesgo** con evidencia técnica, se **aplica el parche**, se **valida la corrección** y todo se **documenta** en reportes formales, sin interrumpir la continuidad operativa.

Red Team → Evidencia → Blue Team → Remediación → Validación

VECTORES AUDITADOS	REPORTES TÉCNICOS FORMALES	FALSOS POSITIVOS INVESTIGADOS
5	5	1

CONTRASEÑAS EN TEXTO PLANO (FINAL)	IMDSV2 SIN TOKEN	SSH EXPUESTO
0	HTTP 401	/32

Principios de trabajo

1. **Identificar sin dañar:** reconocimiento, fingerprinting, SAST y OSINT con técnicas pasivas y no destructivas.
2. **Parchear, no solo recomendar:** cierre de puertos, hardening de configuraciones, sanitización de datos y generación de binarios corregidos.
3. **Validar cada corrección:** códigos HTTP, consultas SQL y re-verificación de advertencias.
4. **Alinear a estándares: ISO/IEC 27001**, **CIS Benchmarks**, **OWASP (WSTG / MASVS)** y **NIST SP 800-115**.
5. **Documentar con honestidad:** matrices de riesgo, estados reales y riesgo residual, sin presentar como terminado lo que no lo estaba.

2. Resumen Técnico de los 5 Mapeos Ejecutados

🌐 Mapeo 1 — Web: aiaco.netlify.app

REP-ASM-2026-S02

- **Metodología:** Caja Negra (Black-Box) bajo NIST SP 800-115 y OWASP WSTG.
- **Herramientas:** Nmap 7.95, Gobuster, Wappalyzer, SecurityHeaders.com.
- **Arquitectura evaluada:** Serverless / hosting estático (Netlify), HSTS activo; métodos PUT, DELETE y TRACE deshabilitados.
- **Resultado:** riesgo global BAJO, 0 fugas de información (sin .env, .git, backups ni paneles admin).
- **Hardening propuesto:** cabeceras HTTP CSP, X-Frame-Options y X-Content-Type-Options.

🔑 Mapeo 2 — Identidades y Base de Datos

REP-ASM-2026-EML01

- **Entorno:** Docker + MySQL 8.0 local sobre Windows + WSL2.
- **Hallazgos:** 3 credenciales en texto plano (incluidas contraseñas extremadamente débiles) y 2 usuarios con hash MD5. Riesgo inicial **CRÍTICO**.
- **Remediación:** Data Sanitization con scripts SQL sobre tabla de respaldo, preservando la evidencia original.
- **Validación:** 0 contraseñas en texto plano, 5 usuarios conservados, integridad intacta. Recomendado: migrar a Argon2 / bcrypt / scrypt.

☁️ Mapeo 3 — Cloud AWS EC2

REP-ASM-2026-AWS01

- **SSH expuesto:** TCP/22 abierto a 0.0.0.0/0 → restricción del Security Group a IP administrativa /32. **Remediado**
- **IMDSv2 Optional:** cambiado a Required; una consulta sin token recibe HTTP 401. **Remediado**
- **Controles positivos:** root login y contraseña SSH deshabilitados, Fail2Ban activo, sin IAM Role asociado (least privilege).
- **Red Team:** sin acceso no autorizado ni extracción de credenciales.
- **Gestión operativa:** investigación documentada de un **falso positivo** (actividad administrativa legítima) y detección de una brecha de procedimiento: falta de notificación previa al equipo de seguridad.

🕵️ Mapeo 4 — OSINT y Dorking

REP-ASM-2026-OSINT01

- **Enfoque:** reconocimiento 100% pasivo, sin generar ruido en los firewalls del objetivo.
- **Análisis:** crawlers e indexación, SEO, `robots.txt`, `sitemap.xml` y Google Dorking (`site:`, `filetype:`, `intitle:`).
- **Conclusión clave:** `robots.txt` no es un control de seguridad; `Disallow` no equivale a autenticación y puede incluso revelar rutas sensibles.

📱 Mapeo 5 — Mobile AppSec (SAST)

REP-ASM-2026-MOB01

- **Herramienta:** MobSF en Docker, bajo OWASP MASVS, sobre un APK de prueba de respaldo.
- **Hallazgos:** Security Score inicial **52/100**; 1 advertencia en Manifest Analysis; 0 vulnerabilidades y 3 advertencias en Code Analysis; exposición en `app.json`/XML/JSON y fallos de autorización de API.
- **Remediación:** hardening de `app.json`, corrección de la autorización de la API y binario parcheado `fixes.apk`.

Índice de Evidencia

#	Vector	Código de documento	Riesgo inicial	Estado
1	Web	`REP-ASM-2026-S02`	Bajo	Completado
2	Identidades / DB	`REP-ASM-2026-EML01`	Crítico	Remediado y validado
3	Cloud AWS	`REP-ASM-2026-AWS01`	Medio–Alto	Remediado y validado
4	OSINT	`REP-ASM-2026-OSINT01`	Estudio / pasivo	Completado
5	Mobile	`REP-ASM-2026-MOB01`	Score 52/100	Remediado (fixes.apk)

3. Stack Tecnológico y Metodologías

☁️ Cloud e infraestructura

`AWS EC2` `VPC` `Security Groups` `IMDSv2` `Fail2Ban` `OpenSSH`

🐳 Contenedores y datos

`Docker` `Docker Compose` `MySQL 8.0` `SQL (Data Sanitization)`

🔎 Reconocimiento y auditoría

`Nmap` `Gobuster` `Wappalyzer` `SecurityHeaders.com` `Google Dorking`

📱 AppSec

`MobSF` `SAST` `AndroidManifest` `app.json / XML / JSON`

🐧 Entornos

`Linux (Kali / Ubuntu)` `WSL2` `Windows` `PowerShell` `VS Code`

📚 Metodologías y estándares

`OWASP WSTG` `OWASP MASVS` `NIST SP 800-115` `CIS Benchmarks` `ISO/IEC 27001` `OWASP Risk Rating` `Agile / SCRUM`

4. Aprendizajes y Propuesta de Valor

Este proyecto me preparó para el trabajo real, no solo para el laboratorio:

1. **Gestión de falsos positivos con criterio:** investigué una alerta sospechosa hasta confirmar que era legítima, sin escalar innecesariamente, y la convertí en una lección de proceso (notificación previa de actividad administrativa).

2. **Documentación de incidentes y hallazgos:** reportes formales, códigos de documento, matrices de riesgo, estados reales y riesgo residual honesto.
3. **Auditoría de punta a punta:** desde la nube (AWS) y las bases de datos, pasando por la web y el OSINT, hasta el código móvil (APK).
4. **Ciclo completo:** detección → evidencia → remediación → validación; no me quedo en el hallazgo.
5. **Mentalidad de cumplimiento:** cada control se conecta con ISO 27001, CIS, OWASP y NIST.

Dónde puedo aportar desde el primer día

Mi formación como **TSU** me da un perfil práctico, de ejecución rápida y orientado a resultados, ideal para integrarme de inmediato a:

Equipo	Aporte inmediato
SOC Nivel 1	Triage de alertas, descarte de falsos positivos, lectura de logs y documentación de incidentes.
Consultoría de Ciberseguridad	Evaluaciones de superficie de ataque, reportes ejecutivos y técnicos, y hardening priorizado.
DevSecOps	Revisión de configuraciones cloud, contenedores y SAST móvil integrables al ciclo de desarrollo.

Jesús Alejandro Rodríguez Medina
TSU en Seguridad Informática · DevSecOps /
Analista de Ciberseguridad Jr.
GitHub: @Alekey2001

✔ PROGRAMA ASM COMPLETADO

Alcance: el sitio web y la aplicación móvil corresponden a activos reales de AICO; los entornos de correo corporativo, redes y cloud (AWS) fueron simulados en laboratorio. Las pruebas se limitaron a recursos autorizados. No se realizó fuerza bruta, explotación destructiva, extracción de credenciales ni ataques a infraestructura ajena.